

LedgerLite Payments API — Requirements Specification

Document ID: LL-SPEC-PAY · Version 2.0 · Status: Approved · Owner: Compliance & Risk Office
Supersedes v1.0. Changes in v2.0 follow the internal payments-risk review and are marked **CHANGED** or **NEW**.

1. Purpose

This document lists the functional and compliance requirements for the LedgerLite Payments API. Every requirement must be implemented in code and covered by at least one automated test before a production release. Auditors verify this traceability for each release.

2. Scope

Customer accounts, deposits, withdrawals, internal transfers, audit logging, and account statements. All amounts are in USD.

3. Requirements

ID	Requirement	Risk
REQ-01	An account can only be created with a unique email address. An account may not send or receive money until its KYC status is verified . Acceptance: duplicate email is rejected; any money movement on an unverified account is rejected.	High
REQ-02	A deposit amount must be greater than 0 and at most 50,000.00 per transaction. Acceptance: 0, negative and 50,000.01 are rejected; 50,000.00 is accepted.	Medium
REQ-03	A withdrawal must never make the account balance negative. Acceptance: withdrawing more than the balance is rejected and the balance is unchanged.	High
REQ-04	A transfer between two accounts is atomic: either both the debit and the credit happen, or neither does. Acceptance: if the credit fails, the debit is rolled back.	High
REQ-05 CHANGED	A transfer of 5,000.00 or more must be held as <i>pending_approval</i> until a second, different user approves it. (<i>v1.0 threshold was 10,000.00.</i>) Acceptance: a 5,000.00 transfer is pending, not completed; the initiator cannot approve their own transfer.	High
REQ-06	Every money movement (deposit, withdrawal, transfer, approval) writes an audit log entry containing actor, action, amount,	High

	account(s) and UTC timestamp. Audit entries cannot be edited. Acceptance: each operation adds exactly one entry; no update endpoint exists for audit entries.	
REQ-07	An account is locked after 5 consecutive failed PIN attempts. A locked account cannot move money. Acceptance: the 5th wrong PIN locks the account; a correct PIN before that resets the counter.	Medium
REQ-08	All monetary values are stored and calculated as exact decimals (never floating point) and returned with exactly 2 decimal places. Acceptance: $0.10 + 0.20$ equals 0.30 exactly; API returns "0.30".	Medium
REQ-09 NEW	Total outgoing transfers per account must not exceed 20,000.00 per UTC calendar day. Acceptance: a transfer that would take the day's total above 20,000.00 is rejected.	High
REQ-10 NEW	Transfers to an account whose country code is on the sanctions list (KP, IR, SY, CU) are blocked and logged. Acceptance: the transfer is rejected with reason <i>sanctions</i> and an audit entry is written.	High
REQ-11 NEW	Account statements must mask account numbers, showing only the last 4 digits (e.g. ****1234). Acceptance: no full account number appears in any statement response.	Medium
REQ-12	Audit log entries must never be deleted through the API (7-year retention). Acceptance: no delete endpoint exists for audit entries; a DELETE request returns 405 or 404.	Medium

4. Release rule

A release is approved only when every requirement above is **implemented** and **covered by at least one passing automated test**, with evidence (file and test name) recorded in the traceability matrix.